

Website Vulnerability Scanner Report

✓ <https://dev-app-brisurf.brins.co.id/login>

Summary

Overall risk level:

Medium

Risk ratings:

Critical:	0
High:	0
Medium:	1
Low:	6
Info:	4

Scan information:

Start time:	Apr 21, 2026 / 15:52:05 UTC+07
Finish time:	Apr 21, 2026 / 17:42:25 UTC+07
Scan duration:	1 hrs, 50 min, 20 sec
Tests performed:	77
VPN Profile:	Scan Internal
Scan status:	Finished

Findings

Insecure cookie setting: missing Secure flag port 443/tcp

CONFIRMED

URL	Cookie Name	Evidence
https://dev-app-brisurf.brins.co.id/login	brins_brisurf_ui_session	Set-Cookie: brins_brisurf_ui_session=eyJpdil6ImJjdGtlcE13dmYzK3B2ZFA0cUtyZ1E9PSIsInZhbHVlIjo iM0pSc0d0cWZUYIZ1RHc4VUpWZ0ZaV3R6WVRPZkhxQVFXYXBZR2Nld1dyak9BbndyV kZSMjhralVBMk5GN1VWbUpjZzFnSjh0YUpxYlZndTBaRnQ2VjMxcEdiUmMvZDRIZVRDb WlpU0ZEQVYwbW45S1h0REF2WHNLR200UTRXM2siLCJtYWMMiOiI4NTI1NGNhMTIiInZyYx ZWNIQ2VIMjJiY2U4ZGRiYzVjMzZlOWFhOGQ3NmZjMGMxMWlxNTJkNWY4YTE3NDhh MjJkIiwidGFmljoiln0%3D Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: X-Content-Type-Options port 443/tcp

CONFIRMED

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

▼ Details

Risk description:

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff`.

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response does not include the HTTP Content-Security-Policy security header or meta tag Request / Response

▼ Details

Risk description:

The risk is that if the target application is vulnerable to XSS, lack of this header makes it easily exploitable by attackers.

Recommendation:

Configure the Content-Security-Header to be sent with each HTTP response in order to apply the specific policies needed by the application.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: Strict-Transport-Security

CONFIRMED

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the HTTP Strict-Transport-Security header Request / Response

▼ Details

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

`Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]`

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.

The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

Missing security header: Referrer-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response. Request / Response

Details

Risk description:

The risk is that if a user visits a web page (e.g. "http://example.com/pricing/") and clicks on a link from that page going to e.g. "https://www.google.com", the browser will send to Google the full originating URL in the **Referer** header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:

The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value **no-referrer** of this header instructs the browser to omit the Referer header entirely.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Robots.txt file found

CONFIRMED

port 443/tcp

URL
https://dev-app-brisurf.brins.co.id/robots.txt

Details

Risk description:

There is no particular security risk in having a robots.txt file. However, it's important to note that adding endpoints in it should not be considered a security measure, as this file can be directly accessed and read by anyone.

Recommendation:

We recommend you to manually review the entries from robots.txt and remove the ones which lead to sensitive locations in the website (ex. administration panels, configuration files, etc).

References:

<https://www.theregister.co.uk/2015/05/19/robotstxt/>

Classification:

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Screenshot:



Figure 4. robots.txt

Internal Server Error Found

port 443/tcp

CONFIRMED

URL	Method	Parameters	Evidence
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: max=https://app.pentest-tools.com/file.txt offset=0 Headers: Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Response has an internal server error status code: 500

Details

Risk description:

The risk exists that attackers could utilize information revealed in Internal Server Error messages to mount more targeted and effective attacks. Detailed error messages could, for example, expose a path traversal weakness (CWE-22) or other exploitable system vulnerabilities.

Recommendation:

Ensure that error messages only contain minimal details that are useful to the intended audience, and nobody else. The messages need to strike the balance between being too cryptic and not being cryptic enough. They should not necessarily reveal the methods that were used to determine the error. Such detailed information can be used to refine the original attack to increase the chances of success. If errors must be tracked in some detail, capture them in log messages - but consider what could occur if the log messages can be viewed by attackers. Avoid recording highly sensitive information such as passwords in any form. Avoid inconsistent messaging that might accidentally tip off an attacker about internal state, such as whether a username is valid or not.

Classification:

CWE : [CWE-209](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A10 - Mishandling of Exceptional Conditions](#)

Screenshot:

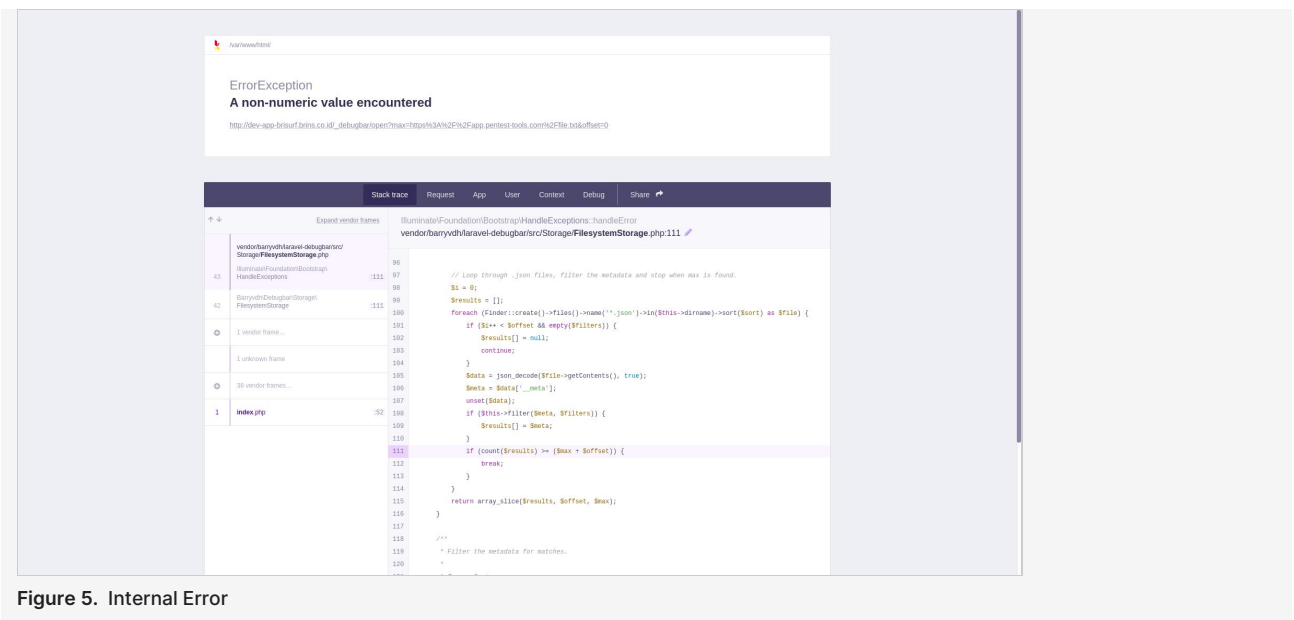


Figure 5. Internal Error

 Login Interface Found
port 443/tcp

CONFIRMED

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	<pre><input type="password" class="form-control" placeholder="Enter Password" aria-label="Username" aria-describedby="basic-addon1" name="password"> <input type="password" class="form-control" placeholder="Enter Password" aria-label="Username" aria-describedby="basic-addon1" name="password"> <button class="btn btn-sm btn-danger" type="submit" id="btn-login">Login</button></pre> Request / Response

▼ Details

Risk description:

The risk is that an attacker could use this interface to mount brute force attacks against known passwords and usernames combinations leaked throughout the web.

Recommendation:

Ensure each interface is not bypassable using common knowledge of the application or leaked credentials using occasional password audits.

References:

<https://pentest-tools.com/network-vulnerability-scanning/password-auditor>
<http://capec.mitre.org/data/definitions/16.html>

Classification:

CWE : [CWE-287](#)
OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Screenshot:



Figure 6. Login Interface

Input Reflected in Response

port 443/tcp

CONFIRMED

URL	Method	Vulnerable Parameter	Evidence	Replay Attack
https://dev-app-brisurf.brins.co.id/login	GET	User-Agent (Http Header)	Injected the string <code>ptt9c6fd9e5</code> in the User-Agent http header and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	User-Agent (Http Header)	Injected the string <code>pttcc3fc7d9</code> in the User-Agent http header and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	captcha (Query Parameter)	Injected the string <code>pttb79b2207`</code> in the captcha query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	ptt5adcf4f1 (Query Parameter)	Injected the string <code>pttfb2cf6b4`</code> in the ptt5adcf4f1 query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	username (Query Parameter)	Injected the string <code>ptt2cd48cff`</code> in the username query parameter and it was found reflected in the response. Request / Response	

Details

Risk description:

The risk is that the reflection of input without proper sanitization or encoding can potentially be leveraged by attackers to inject malicious scripts or content in the client browser context.

Recommendation:

It is recommended that a tester inspects this issue manually to find out if it can be escalated to higher-risk vulnerabilities.

References:

<https://owasp.org/www-community/attacks/xss>
https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Classification:

CWE : [CWE-20](#)
OWASP Top 10 - 2021 : [A3 - Injection](#)
OWASP Top 10 - 2025 : [A05 - Injection](#)

Security.txt file is missing

port 443/tcp

CONFIRMED

URL

Missing: <https://dev-app-brisurf.brins.co.id/.well-known/security.txt>

▼ Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

HTTP OPTIONS enabled

port 443/tcp

CONFIRMED

URL

Method

Summary

<https://dev-app-brisurf.brins.co.id/login>

OPTIONS

We did a HTTP OPTIONS request.

The server responded with a 200 status code and the header: **Allow: GET,HEAD**
[Request / Response](#)

▼ Details

Risk description:

The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:

We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:

<https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845>

<https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/>

Classification:

CWE : [CWE-16](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (77)

Port 443

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for Secure flag of cookie

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for Insecure Direct Object Reference
- ✓ Scanned for internal error code
- ✓ Scanned for misconfigurations
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for robots.txt file
- ✓ Scanned for website technologies
- ✓ Scanned for code comments
- ✓ Scanned for API endpoints
- ✓ Scanned for emails
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for Input Reflected in response body
- ✓ Scanned for login interfaces
- ✓ Scanned for Path Disclosure
- ✓ Scanned for absence of the security.txt file
- ✓ Performed web-crawling on target
- ✓ Scanned for client access policies
- ✓ Scanned for CORS misconfiguration
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for administration consoles
- ✓ Scanned for information disclosure
- ✓ Scanned for software identification
- ✓ Scanned for sensitive files
- ✓ Scanned for interesting files
- ✓ Scanned for GraphQL endpoints
- ✓ Performed fuzzing for OpenAPI files
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for Cross-Site Scripting
- ✓ Scanned for SQL Injection
- ✓ Scanned for Local File Inclusion
- ✓ Scanned for OS Command Injection
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for XML External Entity Injection
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for Server Side Request Forgery
- ✓ Scanned for Open Redirect
- ✓ Scanned for PHP Code Injection
- ✓ Scanned for JavaScript Code Injection
- ✓ Scanned for Ruby Code Injection
- ✓ Scanned for Python Code Injection
- ✓ Scanned for Perl Code Injection
- ✓ Scanned for Remote Code Execution through Log4j
- ✓ Scanned for Server Side Template Injection
- ✓ Scanned for Remote Code Execution through VIEWSTATE
- ✓ Scanned for Prototype Pollution
- ✓ Scanned for Exposed Backup Files
- ✓ Scanned for Request URL Override

- ✓ Scanned for CSRF
- ✓ Scanned for NoSQL Injection
- ✓ Scanned for Insecure Deserialization
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Session Token in URL
- ✓ Scanned for Response Header Injection
- ✓ Scanned for missing HTTP header - Rate Limit

Scan parameters

Target:	https://dev-app-brisurf.brins.co.id/login
Scan type:	Deep_scan_default
Authentication:	False
fingerprint:	True
software_vulnerabilities:	True
check_robots:	True
outdated_js:	True
untrusted_certificates:	True
client_access_policies:	True
http_debug_methods:	True
security_txt:	True
cors_misconfiguration:	True
resource_discovery:	True
sensitive_files:	True
admin_consoles:	True
interesting_files:	True
server_info_disc:	True
server_software:	True
misconfigurations:	True
graphql_endpoint:	True
fuzz_openapi_locations:	True
approach:	True
depth:	Auto
max_time:	10
requests_per_second:	3600
xss:	100
sqli:	True
lfi:	True
oscmdi:	True
ssrf:	True
open_redirect:	True
broken_authentication:	True
php_code_injection:	True
js_code_injection:	True
ruby_code_injection:	True
python_code_injection:	True
perl_code_injection:	True
log4j_rce:	True
ssti:	True
xxe:	True
viewstate_rce:	True
prototype_pollution:	True
backup_files:	True
request_url_override:	True
http_request_smuggling:	True
csrf:	True
insecure_deserialization:	True
nosqli:	True
session_fixation:	True
idor:	True
jwt:	True
response_header_injection:	True
security_headers:	True
cookie_security:	True
directory_listing:	True
secure_communication:	True
weak_password_submission:	True
error_debug_messages:	True
password_cleartext:	True
cross_domain_source:	True

mixed_content:	True
sensitive_data:	True
login_interfaces:	True
file_upload:	True
openapi_documents:	True
path_disclosure:	True
sql_statement_in_request:	True
password_in_response:	True
session_token_in_url:	True
api_endpoint:	True

Scan stats

Unique Injection Points Detected:	100
URLs spidered:	91
Total number of HTTP requests:	18184
Average time until a response was received:	405ms
Total number of HTTP request errors:	277
